

# Security+ 2.4 · An Overview of Malware

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4 — An Overview of Malware (6:06)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

---

**Executive Lesson Summary:** Malware is malicious software. Categorize by: INTENT (espionage, theft, disruption—DoS); FORM (virus, worm, rootkit, trojan, keylogger, ransomware, stealer); CONCEALMENT (packers, polymorphic, metamorphic, fileless).

## High-Yield Core Concepts Tested on Exam

---

- Fileless malware runs in memory, does not touch disk—invisible to traditional AV
- Polymorphic/metamorphic malware changes form to evade signature detection
- Malware can be categorized by intent, form, and concealment techniques
- Packers compress or encrypt malware to avoid detection
- Rootkits hide deep in the OS to maintain persistence
- Ransomware and stealers are common malware types with different objectives

## Exam Tips & Classic Scenarios

---

- 'malware without a file on disk' = fileless malware
- 'changes its code to avoid detection' = polymorphic/metamorphic
- 'hides in memory' = fileless

**Typical Exam Scenario:** A security analyst discovers malware running in memory without any file on disk. This is an example of fileless malware.

## Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — An Overview of Malware)

---

**Why is this advanced coverage required for SY0-701?** Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **WORM:** Write Once, Read Many: Immutable optical/cloud storage paradigm preventing data alteration or deletion during retention periods (critical for audit logs).

### **Classic CompTIA Traps & Question Framing:**

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

## Practice Questions with In-Depth Solutions (10 Questions)

---

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

**1. Malware that encrypts your files and demands payment to return them is:**

- A) Spyware
- B) Ransomware
- C) Rootkit
- D) Worm

**2. Which type of malware spreads automatically across networks without the need for a host file or user interaction?**

- A) Worm
- B) Trojan
- C) Spyware
- D) Adware

**3. An attacker enters as a regular user and becomes 'Domain Admin'. This gain of power is:**

- A) Privilege escalation**
- B) Denial of service**
- C) Social engineering**
- D) Sniffing**

**4. The NIST CSF framework organizes security into 5 functions. What are they?**

- A) Install, Update, Test, Audit, Archive**
- B) Identify, Protect, Detect, Respond, Recover**
- C) Plan, Do, Check, Act, Review**
- D) Prevent, Punish, Predict, Prove, Publish**

**5. Corporate scenario (An Overview of Malware): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Fileless = runs in memory, does not touch disk — invisible to AV'. What is the best recommendation or applicable control classification?**

- A) Implement the corresponding solution: Fileless = runs in memory, does not touch disk — invisible to AV...**
- B) Temporarily disable audit logs to accelerate system throughput**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators using generic credentials**

**6. Corporate scenario (An Overview of Malware): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Polymorphic/metamorphic changes form — evades signature'. What is the best recommendation or applicable control classification?**

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Allow shared access among administrators using generic credentials**
- D) Implement the corresponding solution: Polymorphic/metamorphic changes form — evades signature.**

**7. Corporate scenario (An Overview of Malware):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'malware without a file on disk' = fileless malware'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'malware without a file on disk' = fileless malware...
- D)** Allow shared access among administrators with generic credentials

**8. Corporate scenario (An Overview of Malware):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: malware running without a file on disk = fileless malware.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Scenario: 'malware running without a file on disk' = fileless malware...

**9. Corporate scenario (An Overview of Malware):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Fileless = runs in memory, doesn't touch disk — invisible to AV.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Fileless = runs in memory, doesn't touch disk — invisible to AV.

**10. Corporate scenario (An Overview of Malware):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Polymorphic/metamorphic changes form — evades signatures.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Polymorphic/metamorphic changes form — evades signatures...
- D)** Allow shared access among administrators using generic credentials

## COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

### 1) B — Ransomware.

✓ **Why it is correct:** The correct answer is 'Ransomware'. Ransomware is a type of malware that encrypts the victim's files and demands a ransom payment (usually in cryptocurrency) to provide the decryption key. The statement describes exactly this behavior: malware that encrypts files and demands payment to return them. CompTIA classifies ransomware as a critical threat, often propagated through phishing, vulnerability exploitation, or remote desktop services. Therefore, the option 'Ransomware' is the precise definition of the described attack.

### ✗ **Why the other options are wrong:**

- *Spyware*: Spyware is malicious software designed to collect information from the infected system without the user's consent, such as browsing habits, credentials, banking data, etc. It does not encrypt files or demand ransom. Its primary function is to spy and exfiltrate data. In the scenario, the goal is to extort money through file encryption, which is not a characteristic of spyware. Therefore, spyware does not apply.
- *Rootkit*: A rootkit is a set of malicious tools that allows an attacker to gain privileged access (root) and maintain persistence on the system, hiding its presence from detection mechanisms. Although it can be used in conjunction with ransomware, a rootkit itself does not encrypt files or demand payment. Its purpose is stealth, not extortion. The statement describes a financial extortion attack via encryption, not the installation of a rootkit. Thus, rootkit is not the correct answer.
- *Worm*: A worm is self-replicating malware that spreads automatically across the network, exploiting vulnerabilities, without necessarily needing a host file or user interaction. Although worms can carry payloads like ransomware, they are not defined by encrypting files and demanding ransom. The behavior described in the statement is specific to ransomware, not a worm. Therefore, worm is an incorrect classification for the attack in question.

### 2) A — Worm.

✓ **Why it's correct:** A Worm is a type of standalone malware that self-replicates and spreads automatically across networks, exploiting vulnerabilities in services or operating systems, without the need for a host file or user interaction. Unlike viruses, it does not need a carrier program to propagate. In CompTIA Security+ (domain 2.4 - 'Given a scenario, analyze indicators of malicious activity'), a worm is classically defined as malware that spreads on its own across the network, consuming bandwidth and compromising systems at scale. This is exactly what the question describes.

### ✗ **Why the others are wrong:**

- *Trojan*: A Trojan is malware that disguises itself as legitimate software to trick the user into executing it. It depends on user interaction to infect the system and does not self-replicate automatically across the network. Therefore, it does not meet the criterion of 'spreading automatically without user interaction'.
- *Spyware*: Spyware is malicious software designed to collect user information without consent, such as browsing habits, credentials, and personal data. It does not spread automatically across networks; it is typically installed through social engineering or bundled with other software. Thus, it is not the correct answer.
- *Adware*: Adware is software that displays unwanted advertisements and may redirect the browser, but it does not self-replicate or spread automatically across networks. Its dissemination depends on user installation or other malware. Therefore, it does not meet the question's criteria.

### 3) A — Privilege escalation.

✓ **Why it's correct:** Privilege escalation is the technique in which an attacker, after gaining initial access with a regular user, exploits vulnerabilities, misconfigurations, or poorly protected credentials to elevate their permission level within the system. In the context of CompTIA Security+ (SY0-701), this concept is classified as a post-exploitation tactic (TA0004 in MITRE ATT&CK) and can be vertical (from regular user to administrator) or horizontal (from one user to another with similar privileges). The statement describes exactly the transition from 'regular user' to 'Domain Admin', which is the classic example of vertical privilege escalation in Windows Active Directory environments. Therefore, the correct option is the one that identifies this movement as privilege escalation.

#### ✗ **Why the others are wrong:**

- *Denial of service:* Denial of service (DoS) is an attack that aims to make a resource, service, or network unavailable to legitimate users, typically by overwhelming requests, exhausting resources, or exploiting flaws that cause crashes. In the described scenario, the attacker is not trying to take down the service but to gain more power within the domain. DoS does not involve privilege elevation; it affects availability, not the confidentiality or integrity of permissions. Therefore, it does not apply to the gain of power from regular user to Domain Admin.
- *Social engineering:* Social engineering is the psychological manipulation of people to reveal confidential information or perform actions that compromise security, such as clicking malicious links or providing credentials. Although social engineering can be an initial vector to gain access, it does not describe the technical process of privilege elevation within the system. The statement focuses on the gain of power after access, not the initial method of obtaining it. Therefore, social engineering is not the correct classification for the transformation from regular user to Domain Admin.
- *Sniffing:* Sniffing (or eavesdropping) is the passive interception of network traffic to capture sensitive data, such as cleartext credentials or session information. It is an information-gathering technique, not privilege elevation. Even if sniffing could lead to obtaining administrative credentials, it is not the act of escalating privileges itself. The statement describes the end result (becoming Domain Admin), not the method of traffic capture. Therefore, sniffing is not the correct answer to classify the gain of power.

### 4) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

#### ✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive:* These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.

- *Plan, Do, Check, Act, Review*: This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in quality management and continuous improvement systems, such as ISO 9001. Although the NIST CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do, Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a distortion, as the classic PDCA has four steps.
- *Prevent, Punish, Predict, Prove, Publish*: These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

#### **5) A — Implement the corresponding solution: Fileless = runs in memory, does not touch disk — invisible to AV....**

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (An Overview of Malware): Fileless = runs in memory, does not touch disk — invisible to AV. Fileless malware resides in memory and uses legitimate system tools, making it difficult for traditional antivirus to detect.

#### **✗ Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

#### **6) D — Implement the corresponding solution: Polymorphic/metamorphic changes form — evades signature..**

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (An Overview of Malware): Polymorphic/metamorphic changes form — evades signature. Polymorphic malware mutates its code while keeping the payload, and metamorphic malware rewrites itself entirely, both designed to evade signature-based detection.

#### **✗ Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

#### **7) C — Implement the corresponding solution: 'malware without a file on disk' = fileless malware....**

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (An Overview of Malware): 'malware without a file on disk' = fileless malware. Fileless malware operates in memory, leveraging legitimate system tools to avoid creating files on disk, thus evading traditional file-based detection.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

**8) D — Implement the corresponding solution: Scenario: 'malware running without a file on disk' = fileless malware....**

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (An Overview of Malware): Scenario: 'malware running without a file on disk' = fileless malware. Fileless malware resides in memory, using legitimate system tools (e.g., PowerShell, WMI) to execute malicious activities without writing to disk, making it harder to detect with traditional signature-based antivirus.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

**9) D — Implement the corresponding solution: Fileless = runs in memory, doesn't touch disk — invisible to AV..**

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (An Overview of Malware): Fileless = runs in memory, doesn't touch disk — invisible to AV. Fileless malware operates in memory, often using legitimate system tools, making it difficult for traditional antivirus to detect. The best recommendation is to implement advanced detection techniques such as behavior monitoring, memory analysis, and endpoint detection and response (EDR).

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

**10) C — Implement the corresponding solution: Polymorphic/metamorphic changes form — evades signatures....**

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (An Overview of Malware): Polymorphic/metamorphic malware changes its form to evade signature-based detection. This is a core malware characteristic that requires behavior-based or heuristic detection methods rather than static signatures.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.